MSAAD-Robustness — Project Pipeline & One-Week Sprint

Shirish Giroti (CS23B2041), IIITDM Kancheepuram

Started 30 Oct 2026

> **Schedule update (30 Oct):** the course deadline is **10 Nov 2026**. The day-by-day schedule in `MSAAD_Plan_Nov10.pdf` supersedes the one-week sprint table in §5 below; the gap scan, novelty claim and pipeline stages here are unchanged.

Status and findings so far (2 Nov 2026)

Research notes for the paper — facts and numbers to build on, not paper text.

Stage	Status
S0 environment, S1 leakage-free data layer	done
S2 clean reproduction, IoTID20 (P1)	**gate passed on 3 seeds** (table below)
S2 sensitivity: campaign order, + brute force, all classes	done, 3 seeds (F5)
S2 clean reproduction, CICIoT2023	**gate passed on 3 seeds** (F8)
S3 under-attack harness (Scenario 2) + feasibility audit	**done, 3 seeds, both datasets** (F6, F7, F10)
S3 label-feedback modes (delayed, self-labelled)	**done, 3 seeds, both datasets** (F11)
S3 RADP (Layer 1): MSAPG + GAN + RAD + purification	**done, 3 seeds, both datasets** (F12)
S4 adaptation-loop study + defence	**done, 3 seeds, both datasets (F9) + sweep (F9b)**
S4 importance-weighted strict (IW-strict)	**done, 3 seeds, both datasets (F14)**
Adversarial-training baseline (v13)	**running (2 Nov)**: code tested, grid on the laptop
Figures and tables	generated from the real results; IW-strict included automatically

Where we stand (2 Nov). Every planned experiment has run on both datasets with three seeds; the results can be frozen for the course paper now. The evaluation findings (F2–F7, F10–F13) are solid and new. The headline has moved: the Thompson-Sampling selector is *not* the weak point (F9), the label-feedback channel is. The defence now holds on both counts: strict stops label poisoning (F9, F9b) and its importance-weighted version brings the false-alarm cost to within 0.2–2.5 points of the paper's rule at 10–20% verified labels (F14).

Run queue (1 Nov). Each grid runs three seeds, three at a time; two grids side by side are fine on the laptop. Commands are in the Setup Guide. From now on every run is journalled in `RUNS.md` and pushed to the private repository (Step 15).

#	Run	Setup Guide	Send to Claude	Status
1	Attack grid, IoTID20	Step 10	`results\attack_grid\summary_attack.csv`	done (F6, F7)
2	Clean grid incl. CICIoT2023	Steps 5, 6, 9	inspector report, `results\grid\summary.csv`	done (F8)
3	RADP quick look, IoTID20 (`--limit 3000`)	Step 12	`results\radp\iotid20_seed42.csv`	done
4	Attack grid CICIoT2023, then label grid on both datasets	Steps 10, 11	`summary_attack.csv` , `summary_attack_labels.csv`	done (F10, F11)
5	RADP grid, both datasets	Step 12	`results\radp_grid\summary_radp.csv`	done (F12)
6	Adaptation-loop grid (S4), both datasets	Step 13	`results\loop_grid\summary_loop.csv`	done (F9)
8	S4 sweep: smaller q, other audit rates	Step 13 part 4, `--tag sweep`	`results\loop_grid` (zip)	done (F9b); per-seed JSONs in the repository
9	IW-strict grid (v10), both datasets, 57 min	Step 13 part 5, `--tag iw`	`results\loop_grid\summary_loop_iw.csv`	done (F14)
10	Private GitHub repository; push after every run (`--push`)	Step 15	the pushed repository	done (2 Nov)
7	Figures and tables	Step 14	the `results\paper` folder (zip it)	done on current results; re-run after #11
11	Adversarial-training baseline (v13), both datasets, ~3 h	Step 16, `--exp advtrain`	`results\advtrain_grid\summary_advtrain.csv`	running (2 Nov)

Why #11. The first question a reviewer asks of an evasion result is "why not adversarial training?". Three detectors per run, identical attacker: no adversarial training, trained on repaired PGD copies only (FGSM, BIM and C&W unseen; BIM is a near-copy of PGD), and trained on all four attacks. Expected outcomes and what each means for the paper: (a) it stops evasion without labels at little false-alarm cost → a strong second baseline, and the paper compares it with the label-channel defence; (b) it helps on seen attacks only, or costs many false alarms → evidence that the label channel, not the detector's training data, is where robustness has to come from. Either outcome goes in the paper. Limitation to state: the attacker is not adaptive (it does not re-train against the hardened detector), so the numbers are an upper bound on what adversarial training buys.

F1 — The clean result reproduces. IoTID20, P1 (file order), 50,000 flows, 3 seeds, mean ± std. The seeds vary only the models' randomness; every seed sees the same flows.

Metric	Ours	Paper
Accuracy	99.33 ± 0.08	99.50
Precision	99.33 ± 0.07	99.47
Recall	99.91 ± 0.02	100

F1	99.62 ± 0.05	99.74
False-alarm rate	4.98 ± 0.51 %	not reported

Our setup is stricter than the paper's: running (leakage-free) scaling, no oversampling in the evaluated stream, exact KNN-ADWIN, and a learning bandit.

F2 — Accuracy hides false alarms. About 5% of benign flows are flagged as DDoS (4.98 ± 0.51% over 3 seeds, ~300 of ~6,000), against ~40 missed attacks. A model that always says "attack" already scores ~88% accuracy on this subset. This matters because the paper's defence *deletes* flagged traffic. (v6+ reports the false-alarm rate directly.)

F3 — IoTID20's file order carries no drift. Only 50.0% of consecutive rows are in time order and every tenth of the file has the same class mix: the public CSV is shuffled. The paper's "3 concept drifts" on IoTID20 therefore cannot reflect real change in the traffic.

F4 — IoTID20 confounds class with capture date. All 40,073 benign flows were captured in the first week (20–26 May 2019); everything after is attack traffic (DoS/ARP spoofing, then scans, then Mirai floods on 11–25 Jul, then brute force to 10 Sep). A plain time-ordered replay is a single all-benign → all-attack switch, and any model could separate the classes by capture-session artefacts. Our P2 protocol ("campaign order") keeps attacks in their real order with benign flows spread evenly as background.

Measured (3 seeds): the time-ordered replay (`iotid20_time`) scores 99.99 ± 0.01% accuracy, 100.00% F1 and 0.00% false alarms, so the replay order alone produces a perfect score. About 85% of the UDP/ACK/HTTP flood flows in our subset (~250,000 of 294,496) were captured within seven minutes (25 Jul 2019, 03:20–03:27), two months after the last benign flow.

Prior work on IoTID20's validity (checked 1 Nov). IoTGeM (Kostas, Just & Lones, preprint submitted to Elsevier, arXiv 2401.01343), Appendix A.3, re-extracted the IoT-NID pcaps and reports that IoTID20's feature extraction / labelling looks flawed: the raw data has 10 attacks but IoTID20 has 8; the attack pcaps also contain benign packets, yet IoTID20 appears to label whole attack files as attacks; and for several attacks IoTID20 has MORE flows than the raw data has attack packets (their Table 8; a flow holds at least one packet), e.g. Telnet brute force 1,924 packets vs 121,181 flows and HTTP flooding 10,464 packets vs 55,818 flows (UDP, ACK and SYN floods are consistent). IoTGeM does not report the file shuffling, the class/capture-date confound or the degenerate time replay: F3 and F4 are new observations. Cite IoTGeM for the labelling problems; together they are a threat-to-validity paragraph for every IoTID20 result, including the base paper's.

Hypothesis H5 (links F5 to IoTGeM). By IoTGeM's counts at least 98% of the 121,181 "brute force" flows cannot be brute-force attack flows, so adding that class teaches the detector to call benign-looking flows "attack" — consistent with false alarms jumping from 5% to 12% (F5). Our default subset contains HTTP flooding, where at least 81% of the 55,818 flows cannot be attack flows either. Check: per-class evasion (`asr_by_class` in the attack JSONs) — mislabelled, benign-looking classes should evade far more often than UDP/ACK floods.

H5 result (1 Nov): not supported. IoTID20, repaired PGD, no labels, per class over the 3 seeds: HTTP flooding 23.4 / 29.1 / 34.3%, ACK flooding 23.5 / 29.1 / 33.7%, UDP flooding 6.2 / 8.3 / 11.1%. HTTP (mostly not attack flows by IoTGeM's counts) evades no more than ACK (consistent counts); UDP floods are simply harder to disguise. The other attacks show the same pattern (FGSM: 29–31% vs 29–31% vs 8.5–9.0%). Report it as a checked and rejected explanation; the false-alarm jump in F5 still needs one.

Speed numbers: grid throughput depends on how many runs share the CPU (the same `iotid20_time` run took 10.0 min with four runs in parallel and 3.7–3.8 min with fewer; P1 ran at ~73 flows/s in the morning grid and comparable runs at ~154 flows/s later). Speed figures for the paper must come from dedicated single-run timings.

F5 — The subset choice moves false alarms, not accuracy. IoTID20, 50,000 flows, 3 seeds:

Stream	Accuracy	F1	False-alarm rate
P1 file order (Normal + UDP/HTTP/ACK floods)	99.33 ± 0.08	99.62 ± 0.05	4.98 ± 0.51 %
P2 campaign order (same rows)	99.41 ± 0.04	99.67 ± 0.02	3.85 ± 0.58 %
+ Mirai brute force (the paper's listed "DDoS types")	98.85 ± 0.37	99.37 ± 0.21	12.15 ± 3.82 %
All attack classes	99.15 ± 0.20	99.55 ± 0.10	12.20 ± 3.18 %
Time order (degenerate, F4)	99.99 ± 0.01	100.00	0.00 %

The real attack-campaign drift (P2) does not hurt MABTSE: the floods are easy to separate from benign IoT traffic. Adding brute force or all classes moves accuracy by < 0.5 points but multiplies false alarms by ~2.4 (about one benign flow in eight flagged).

F6 — Under the paper's own protocol the attacks do nothing; without labels gradient-sign attacks evade ~16% of DDoS flows. The paper's collapse is not reproduced. IoTID20, 30,000 flows (train 20,100 / test 9,900), 3 seeds. Attacker: MLP surrogate trained on the same clean training flows, eps 0.1 in the scaled space, perturbing DDoS flows only (attack_only). ASR = share of perturbed DDoS flows classified benign (%).

Attack	ASR online (instant labels)	ASR frozen (no labels)	Accuracy online / frozen
none (clean miss rate)	0.08	0.08	99.49 / 99.48
FGSM	0.07 ± 0.05	17.05 ± 2.42	99.78 / 84.61
BIM	0.09 ± 0.02	15.80 ± 3.99	99.75 / 85.72
PGD	0.09 ± 0.04	15.94 ± 3.14	99.71 / 85.59
C&W	0.09 ± 0.01	5.85 ± 3.51	99.45 / 94.43

- The paper reports accuracy falling to 38.92–67.12% on IoTID20 under these attacks. Under its own Algorithm 1 (true label at once) the evasion gain is zero for every attack (-0.03 to +0.05 points); with no labels accuracy stays at 84.6–94.4%.
- C&W is the weakest attack here, not the strongest as the paper reports: its minimal perturbations fool the surrogate on every flow but rarely carry over to the tree ensemble (6% vs 26% in the 3,000-flow quick look, which had a weaker surrogate).
- Side observation to investigate: under instant labels the attacked runs have FEWER false alarms than the clean run (1.2–2.2% vs 3.6% for FGSM/BIM/PGD).
- Reading: robustness in the paper's setting comes from the instant-label assumption, not from the defence layers. This motivates the label-channel experiments (Step 11, S4).

F7 — Every raw adversarial flow is impossible traffic, yet valid (repaired) attacks evade just as well. In the 3,000-flow run, 100% of the raw FGSM/BIM/PGD/C&W DDoS vectors break at least one constraint mined from clean flows (15 constant, 5 binary, 5 categorical, 30 integer, 63 non-negative features, 7 equality groups, 24 Min ≤ Mean ≤ Max orderings); the full runs' audits are in the result JSONs. After the monotone repair (never enlarging any feature's change), frozen ASR over 3 seeds: FGSM 17.05 → 16.59, BIM 15.80 → 15.55, PGD 15.94 → 16.07, C&W 5.85 → 4.45 — all inside one seed standard deviation. The evasion lives in features an attacker can really change. Hypothesis for RADP: RAD separates raw attacks by their impossible values, so its detection should drop on the repaired ones.

F8 — CICIoT2023 reproduces. Source: a pre-split Kaggle copy of CICIoT2023 (https://www.kaggle.com/datasets/himadri07/ciciot2023;

`CICIOT23/test/test.csv`, 1,176,851 rows, the original 46 features and 34 labels; rows shuffled — every tenth of the file has the same class mix). The page does not document how the split was made: state this in the paper, together with the checks above. DDoS + benign subset: 883,690 rows, benign 3.1% (always answering "attack" scores 96.9%). 50,000 flows (stride), 3 seeds:

Metric	Ours	Paper
Accuracy	99.76 ± 0.10	99.28
Precision	99.80 ± 0.09	98.88
Recall	99.95 ± 0.02	96.53
F1	99.87 ± 0.06	97.98
False-alarm rate	6.19 ± 2.78 %	not reported

The paper's own CICIoT2023 figures are inconsistent: precision 98.88 and recall 96.53 give F1 = 97.69, not the 97.98 it reports.

F9 — S4: the adaptation loop is both MABTSE's defence and its weak point; asymmetric trust fixes it. 30,000 flows, 3 seeds. Attacker: the repaired (valid) PGD of F7 on its own DDoS flows; a fooled labeller calls each of those flows benign with probability q; audits verify a random 10% of all flows. ASR (%) under evasion + poisoning, poisoning alone in brackets:

Policy	IoTID20 q=0	q=0.5	q=1	CICIoT2023 q=0	q=0.5	q=1
no learning	16.07 (0.08)	—	—	83.72 (0.08)	—	—
vanilla (paper)	0.12	48.61 (50.73)	99.74 (99.64)	0.08	46.99 (46.41)	99.97 (99.80)
audit (selector only)	0.13	35.31 (37.83)	99.55 (99.48)	0.10	28.31 (30.09)	99.90 (99.64)
guard	0.13	0.33 (0.07)	68.41 ± 37.66 (0.16)	0.10	0.19 (0.16)	67.42 ± 55.58 (0.43)
strict	0.12	0.21 (0.06)	0.92 (0.08)	0.11	0.15 (0.07)	0.49 (0.10)

False alarms (%), true labels, clean traffic / under attack: vanilla 3.56 / 2.23 (IoTID20), 3.30 / 2.00 (CICIoT2023); strict 4.92 / 4.62 and 9.11 / 17.72 ± 9.53; no learning 3.59 / 4.20.

- With instant true labels every policy neutralises even CICIoT2023's strong attack (83.7% evasion without learning → ~0.1%): F6 holds on both datasets.
- Poisoning alone, with no perturbation at all, lets about q of the DDoS flows through under the paper's rule; at q = 1 the detector inverts (accuracy 12.7% IoTID20, 3.6% CICIoT2023).
- Securing only the Thompson-Sampling selector (audit) helps at q = 0.5 (−13 to −19 points) and not at all at q = 1. Selection shares barely move: on IoTID20 the selector always keeps ARF-DDM, SRP-ADWIN and SRP-DDM and never picks ARF-ADWIN or KNN-ADWIN (each flags ~85% of benign flows on its own). The poison acts through the learners, not by steering the selector.
- guard contains poisoning alone and q = 0.5 but fails at q = 1 with evasion, unstably across seeds: evaded attacker flows labelled benign agree with the verdict, are learned, and make the next flows evade (a self-reinforcing loop).
- strict (10% verified) keeps ASR below 1% in every case on both datasets. Its cost is false alarms (+1.4 to +15.7 points). The worst case — CICIoT2023, true labels, under attack — comes from learning the attacker's perturbed flows as DDoS with no benign counterweight, which pushes the boundary into benign traffic: a remaining availability lever to discuss in the paper.
- CICIoT2023, repaired PGD, no learning: accuracy 18.95 ± 11.16%, inside the range the paper reports for CICIoT2023 under attack (13.08–32.38%). IoTID20 is not reproduced (85.5% vs 38.92–67.12%). Compare all four attacks once the CICIoT2023 attack grid is read.

F9b — S4 sweep (1 Nov): the poisoning curve is threshold-like, and the verified-label budget trades evasion for false alarms. Same setup as F9; the sweep adds q = 0.1, 0.25 for vanilla and verified shares of 1%, 5%, 20% for strict (numbers rebuilt from the sweep log; the per-seed JSONs are still to be sent).

vanilla, ASR (%)	q = 0.1	0.25	0.5	1
IoTID20, poisoning only / + evasion	0.73 / 0.27	4.87 / 3.46	50.73 / 48.61	99.64 / 99.74
CICIoT2023, poisoning only / + evasion	0.30 / 0.20	1.85 / 1.66	46.41 / 46.99	99.80 / 99.97

strict, verified share	1%	5%	10%	20%	vanilla
IoTID20 ASR, evasion + q=1	4.42 ± 1.96	1.37 ± 0.19	0.92	0.48 ± 0.17	99.74
IoTID20 FPR clean / under attack	6.65 / 25.13	5.32 / 7.47	4.92 / 4.62	4.62 / 4.35	3.56 / 2.23
CICIoT2023 ASR, evasion + q=1	2.92 ± 1.33	0.75 ± 0.29	0.49	0.35 ± 0.13	99.97
CICIoT2023 FPR clean / under attack	19.62 / 38.84	13.92 / 25.52	9.11 / 17.72	7.01 / 11.11	3.30 / 2.00

- Up to a quarter of the attacker's flows mislabelled, the loop absorbs the poison (< 5% evasion); at half it lets about half through; at all of them, everything. The jump between 0.25 and 0.5 matches the threshold behaviour predicted for label attacks on online learners (Margiotta, Goldt & Sanguinetti, NeurIPS 2023). A finer grid (0.3, 0.4) would pin it down.
- Even 1% verified labels hold evasion under 5% at q = 1. The price is false alarms, and it falls as the budget grows; on CICIoT2023 under attack it is still 11.1% at 20% verified (vanilla 2.0%).
- Mechanism check: with q = 1 the strict false alarms under attack drop back (IoTID20 3.9–4.5%, CICIoT2023 3.8–9.0%, against 4.4–25.1% and 11.1–38.8% with true labels), because the attacker's flows now carry benign labels that strict skips. The cost comes from learning the attacker's perturbed, benign-looking flows as DDoS with benign traffic learned only from audits. IW-strict (v10, run #9) re-weights each audited benign flow by 1/a to restore that counterweight without trusting a single unverified benign label. On a hard synthetic stream it removed about a third of strict's extra false alarms; run #9 measures it on the real data.

F10 — CICIoT2023 under attack: without labels the detector collapses, and repaired (valid) attacks are stronger and steadier than raw ones. 30,000 flows, 3 seeds, setup as F6.

Attack	Instant labels	No labels, raw	No labels, repaired	Accuracy, repaired
FGSM	0.05	64.49 ± 53.38	79.57 ± 18.76	22.96
BIM	0.05	64.58 ± 53.45	84.68 ± 12.42	18.03
PGD	0.06	58.59 ± 49.06	83.72 ± 11.51	18.05

PGD	0.06	58.59 ± 49.96	83.72 ± 11.51	18.95
C&W	0.09	81.29 ± 15.46	86.55 ± 11.13	16.22

- With instant true labels nothing gets through (≤ 0.12% for every attack, raw or repaired): F6 holds on both datasets.
- Without labels, accuracy falls to 16–23%, inside the 13.08–32.38% the paper reports for CICIoT2023 under attack. So the paper's CICIoT2023 collapse reproduces, but only once the label feedback its own Algorithm 1 relies on is removed.
- Raw FGSM/BIM/PGD are bimodal across seeds (seed 1: 99.7%, seed 2: 73–91%, seed 3: 3%); repaired versions evade 62–99% on every seed. Impossible feature values can be *caught*, so raw-space evaluation can understate the threat: feasibility is not just a constraint that weakens attacks. The figures show every seed as a dot for this reason.
- Which DDoS classes evade changes with the seed (repaired PGD: ICMP flood 0.4% on seed 1, 99.7% on seed 2): transfer depends on the surrogate. Five seeds for CICIoT2023 would make the means steadier for the paper.
- Seed 1: repaired FGSM, BIM and PGD give identical results (78.05%): the repair maps the three perturbations to the same valid flows. A sign that, on CICIoT2023, the repair (rounding, orderings) decides much of the final perturbation.
- Caveat for the paper: the constraint miner treats CICIoT2023's window features (`Number` , `Weight`) as continuous.

F11 — Label delay decides evasion; self-labelling does not protect. Raw PGD and C&W, ASR (%) when true labels arrive D flows late:

	instant	100	1,000	5,000	no labels	self-labels
IoTID20 PGD	0.09	0.22	1.77	8.50	15.94	15.03
IoTID20 C&W	0.09	0.17	0.96	3.30	5.85	0.28
CICIoT2023 PGD	0.06	0.68	6.20	30.07 ± 25.46	58.59	66.70 ± 57.67
CICIoT2023 C&W	0.09	0.90	7.94	40.84 ± 8.15	81.29	49.53 ± 48.57

- Evasion grows smoothly with the delay. At flood rates 1,000–5,000 flows is seconds of traffic, so "instant labels" is the assumption doing the work in the paper's robustness.
- Self-labelling (learning the model's own verdicts) gives no protection on average and is bimodal on CICIoT2023; the one exception is C&W on IoTID20 (0.28%), whose small perturbations are mostly still classified correctly, so the self-labels are mostly right.

F12 — RADP (the paper's Layer 1) detects impossible values, not adversarial traffic. 3 seeds, detector frozen. Flagged: perturbed DDoS flows RAD deletes. ASR: DDoS flows that get through end to end.

	IoTID20	CICIoT2023
RAD hold-out accuracy (the paper-style check)	99.4–100%	99.4–100%
GAN fidelity (C2ST AUC, 0.5 = indistinguishable)	1.000	1.000
Flagged, raw attacks	100% (C&W 93.9)	100% (C&W 99.2)
Flagged, repaired attacks	13.0–13.7%	98.9–99.8%
Flagged, repaired, RAD without the GAN	36.5–47.3%	98.9–99.9%
ASR repaired PGD: no RADP → with RADP	16.1 → 12.5	83.7 → 0.7
Benign flows deleted (with / without GAN)	0.1 / 0.1%	18.4 ± 17.7 / 4.8 ± 2.1%
Unseen C&W (leave-one-out), repaired: flagged → ASR	0.0% → 4.5	19.9% (seeds 60 / 0 / 0) → 71.7

- On IoTID20 RAD separates raw attacks by their impossible values (F7's hypothesis confirmed) and misses 87% of the repaired ones; the GAN's samples make it worse.
- On CICIoT2023 it catches the known attacks, repaired or not, but deletes 18% of legitimate flows (22% of benign traffic lost with false alarms) and misses C&W when it has not trained on it: an "unknown attack" claim the paper never tested (gap 5).
- The GAN never produces samples a classifier cannot tell apart from the real adversarial ones (AUC 1.000 everywhere) and only adds collateral damage (4.8% → 18.4% benign deleted on CICIoT2023).
- The paper's "recovered accuracy" (survivors only) hides this: on clean CICIoT2023 traffic it reads 99.8% while 22% of benign traffic is lost (gap 10).

F13 — The paper's attack setting perturbs benign traffic too. Perturbing every flow ("all", which an attacker controlling only its own flows cannot do), no labels, PGD: false alarms 65.1 ± 11.7% (IoTID20) and 78.4 ± 9.6% (CICIoT2023), accuracy 78.0% and 40.8%. This moves IoTID20 toward the paper's 38.92–67.12% but does not reach it; the realistic setting (attacker's flows only) is F6 / F10.

F14 — IW-strict removes most of strict's false-alarm cost at 10–20% verified labels, and evasion stays ≤ 1.2% under full poisoning. 30,000 flows, 3 seeds, paired with strict (same seeds, audit and label masks). False alarms (%) with true labels, clean / under the repaired PGD attack; ASR (%) under evasion + full poisoning (q = 1):

Dataset	Verified	strict FPR	IW-strict FPR	strict ASR	IW-strict ASR
IoTID20	5%	5.32 / 7.47	6.63 / 11.36 ± 9.30	1.37	1.74
IoTID20	10%	4.92 / 4.62	4.35 / 2.99	0.92	1.19
IoTID20	20%	4.62 / 4.35	4.13 / 2.39	0.48	0.46
CICIoT2023	5%	13.92 / 25.52	8.61 / 16.52	0.75	0.83
CICIoT2023	10%	9.11 / 17.72	5.70 / 4.51	0.49	0.51
CICIoT2023	20%	7.01 / 11.11	4.70 / 3.40	0.35	0.33

Paper's rule (vanilla): FPR 3.56 / 2.23 (IoTID20), 3.30 / 2.00 (CICIoT2023); ASR 99.74 / 99.97.

- At 10–20% verified, IW-strict costs +0.2 to +2.5 points of false alarms over the paper's rule (strict: +1.1 to +15.7). CICIoT2023 under attack: 17.7% → 4.5% at 10%, 11.1% → 3.4% at 20%.
- Robustness is kept: ASR ≤ 1.2% under evasion + full poisoning (IoTID20 0.92 → 1.19 at 10%; CICIoT2023 unchanged), ≤ 0.4% under poisoning alone. Vanilla lets 99.7–100% through.
- At 5% verified, 20 copies per audited benign flow are too many: IoTID20 gets worse and unstable (11.4 ± 9.3% under attack) and CICIoT2023 improves but stays high (16.5%). Design rule for the paper: re-weighting needs about 10% of flows verified; below that, verify more rather than weight more (a lower copy cap is untested).
- Under full poisoning IW-strict's false alarms are lowest (CICIoT2023 1.5–4.6%): the attacker's flows arrive labelled benign and are skipped, as the F9b mechanism predicts.
- Selection shares do not move here either (IoTID20 keeps ARF-DDM, SRP-ADWIN, SRP-DDM), as in F9.

S4 design (v9) — what the adaptation-loop experiment tests. F6 says MABTSE's robustness comes from learning true labels at once. S4 asks what

happens when the label source is also fooled: each of the attacker's flows is labelled benign with probability q. Questions: (1) how fast does label poisoning turn adaptation against the detector, alone and combined with evasion; (2) does it steer the Thompson-Sampling selector (selection shares, posterior means; per-learner evasion from the frozen runs); (3) which update policy contains it — protecting only the selector (`audit`), verifying downgrades of flagged flows (`guard`), or never learning an unverified benign label (`strict`) — and at what false-alarm cost. Mock-data tests only check the machinery; the real numbers come from the Step 13 grid.

0. What we are doing, in one paragraph

We take a published online IoT DDoS **defence** (Beshah et al., MSAAD, IEEE Access 2025), reproduce it faithfully, and then do what the paper did not: evaluate its robustness *properly* and build a **more robust, better-justified** version. The work is defensive and runs entirely on public benchmark datasets (IoTID20, CICIoT2023) against our own reimplemented model. The headline novel contribution is a rigorous study of the **adaptation loop** — the Thompson-Sampling classifier selector, the ADWIN/DDM drift detectors, and the label-feedback channel — which the base paper leaves completely untested, plus a corruption-robust update rule for that loop (results: the label channel, not the selector, is the weak point; see §1).

1. The claim we can defend as novel

Revised after the results (1 Nov). The selector hypothesis below was tested and did not hold (F9: securing the selector barely helps, selection shares do not move; the poison acts through the learners). The claim the results support:

> *The robustness of an adaptive online IoT DDoS detector (MSAAD) rests on an instant, trustworthy label channel. With true labels at once, evasion is neutralised; as labels are delayed it returns (F11), and an attacker who makes the labeller call its own flows benign turns the adaptation loop against the detector, with a threshold-like effect in the poisoned share (F9, F9b). Protecting the bandit selector does not help. One-sided label trust with a small random audit budget (strict) bounds evasion below 1% at 10% audits, and weighting each verified benign flow by the inverse audit rate (IW-strict) brings its false-alarm cost to within 0.2–2.5 points of the paper's rule at 10–20% audits (F14). The paper's Layer 1 (RADP) detects impossible feature values rather than adversarial traffic (F12).*

Prior work to position against (checked 1 Nov): label attacks on online learners are known in theory — Margiotta, Goldt & Sanguinetti, "Attacks on Online Learners: a Teacher-Student Analysis", NeurIPS 2023 (threshold-like accuracy drop, no defence); poisoning of an online network anomaly detector with a bounded-false-positive protection — Kloft & Laskov, "Security Analysis of Online Centroid Anomaly Detection", JMLR 13:3681–3724, 2012; defences for online poisoning including a labelling-oracle defence — Wang, Jha & Chaudhuri, "An Investigation of Data Poisoning Defenses for Online Learning", arXiv 1905.12121, 2019. What none of them do: evaluate a published adaptive IoT DDoS detector under an attacker that controls only its own flows, combine evasion with label poisoning, test the bandit selector as the lever (negative result), or give a one-sided trust rule with its audit-budget / false-alarm trade-off.

The original claim (30 Oct), kept for the record:

> *No prior work evaluates or hardens the online model-selection loop of a streaming IoT DDoS detector.* Bandit reward-poisoning is known in theory (Liu & Shroff, ICML 2019; Jun et al., NeurIPS 2018) and Thompson-Sampling **routing** exists in IDS (IDS-Anta / SHIELD-IDS), but nobody has studied that selector as a weak point, nor replaced it with a corruption-robust selector, for an online DDoS detector — with end-to-end metrics and a leakage-free streaming protocol.

This is the "don't reinvent the wheel" choice: it reuses the base paper's own design as the baseline, needs no new dataset to be novel, and is cheap enough to finish on a laptop.

2. Gap scan — what is wrong with the base paper (the openings we exploit)

Grouped by how we turn each gap into a contribution. (Severity is our reading against the Carlini / Tramèr / Arp evaluation standards.)

#	Gap in the base paper	Severity	We turn it into
1	No threat model (attacker knowledge / capability / goal never stated; benign *and* attack samples perturbed although an attacker controls only attack traffic)	Critical	A formal threat model, re-run under each cell
2	Gradient attacks on non-differentiable River models imply an undisclosed surrogate → transfer attacks mislabelled white-box	Critical	Attacks that need no surrogate; report the surrogate-vs-direct gap
3	Unconstrained ε=0.1 over all features (incl. one-hot / counts) → many "adversarial" samples are not valid traffic	Critical	Feasibility-constrained evaluation; measure how many of the paper's perturbations are invalid
4	No adaptive / defence-aware evaluation	Critical	Defence-aware robustness tests (EOT over the random selector)
5	"Unknown attacks" never actually tested (RAD trained on the same four attacks/ε it is tested on)	High	Leave-one-attack-out + ε sweep → the real generalisation gap
6	Layers 2–3 give no measured robustness; all recovery comes from RADP deletion; no ablation	High	Full ablation isolating each layer
7	"Hard to replicate" pool claim untested; 4/5 learners are the same family	High	Transfer / extraction test of the claim
8	Bandit never learns as printed; reward undefined → **the selector is an unstudied weak point**	High	**Headline:** selector-robustness study + corruption-robust selector
9	Purification = deletion → RAD false positives are self-inflicted DoS; TPR/FPR never reported	High	Report detector TPR/FPR + benign-drop
10	"Recovered accuracy" computed only on surviving samples (near-tautological)	Critical	End-to-end metrics (attack-success rate, benign-drop)
11	Tiny streams; drifts fall in warm-up	Medium	Full-scale prequential streams
12	Leakage risks (global min-max, offline feature selection, in-stream SMOTE)	High	Strictly leakage-free streaming pipeline (**already built** in `preprocessing.py`)
13	Single run; unnamed statistical test	Medium	Multi-seed runs + CIs + named test
14	Internal inconsistencies (precision reported as accuracy; impossible F1 values; swapped legends)	Medium	A corrected, open reproduction is itself a contribution

15	Throughput far below flood rates; no edge numbers; RADP overhead unmeasured	High	Latency/throughput measurement (optional edge board)

3. Current advancements and where they still leave room

- **Drift-detector poisoning** (Korycki & Krawczyk 2023; "Online AutoML" arXiv 2610.05810, 2026; "Learn to Adapt" 2206.07581) — this area is now crowded, so we keep drift-detector manipulation as a *secondary* experiment, not the headline, and cite it explicitly.
- **Adversarial-vs-natural drift** (AISec 2024; AMDS 2026) — AMDS even names "distinguishing genuine attack evolution from adversarial manipulation of the learning signal" as open. We cite it as motivation, not overlap.
- **Thompson-Sampling routed IDS** (IDS-Anta, SHIELD-IDS 2026) — they *use* a bandit selector but never study it as a weak point. **That is precisely our gap.**
- **Constrained tabular robustness** (CAPGD/CAA, TabularBench) and **exact tree-ensemble evaluation** (Kantchelian ICML 2016) are mature tools we *reuse* rather than reinvent.
- **Corruption-robust bandits** (robust Thompson Sampling, arXiv 2410.19705; BARBAR) give us an off-the-shelf, citable defence with regret guarantees.
- **Label attacks on online learners** (Margiotta et al., NeurIPS 2023; Kloft & Laskov, JMLR 2012; Wang, Jha & Chaudhuri 2019) — the general idea is known; our contribution is the measured, system-level version on a published IoT DDoS detector plus the one-sided defence. Cite all three.

Net (30 Oct): the selector-loop angle is open; everything we need to evaluate it is a mature, reusable library. **Update (1 Nov):** the selector turned out not to be the lever; the label channel is, and its general idea has prior work, so the paper's novelty is the realistic threat model, the measurements and the one-sided trust defence (§1).

4. The project pipeline (permanent stages)

Each stage has an owner module, an output, and a gate. Stages run roughly in order; S5/S6 interleave once S4 produces results.

Stage	Name	Output	Gate
S0	Environment & repo	runnable scaffold	`smoke_test.py` PASS ✅ (done)
S1	Leakage-free data layer	prequential streamers + running scaler	loads both datasets in order, no shuffle ✅ (built)
S2	Reproduce MABTSE (the defence)	clean accuracy on both datasets	within ~1–2 pts of 99.50 / 99.28
S3	Robustness harness + end-to-end metrics	ASR / benign-drop / TPR-FPR instruments on our own model	metrics produced on a dry run; RADP (Layer 1) reproduced
S4	**Novel:** adaptation-loop study + robust update rule	label-channel result + update policy (strict / IW-strict)	a policy that bounds evasion under poisoning vs vanilla under the same test ✅ (strict, F9); open: its false-alarm cost
S5	Benchmarking	multi-seed, ablations, cross-dataset, (optional) edge latency	all headline tables multi-seed with CIs
S6	Writing + artifact	paper + open-source repo + Zenodo DOI	preprint posted; submission packaged

Compute note. S2 and S5 are CPU-bound (River tree ensembles) — your i7-14650HX handles the 50k–200k subsamples in minutes per run. The **RTX 5060 matters only at S3+** (training the RADP GAN and any differentiable surrogate; ~1–4 GPU-hours each, fits in 8 GB with small batches). Plan GPU sessions around S3/S4, not S2.

5. The one-week sprint (30 Oct → 6 Nov 2026)

Baseline target: a **B-tier** venue is the floor; the A-tier plan (DSN / EuroS&P 2027) is the stretch. This week is S0–S2 plus the start of S3.

Day	Goal	Gate / fallback
D1 (done)	Repo + pipeline + MABTSE reproduction code; smoke test green	✅ pipeline learns synthetic stream
D2	Download IoTID20 + CICIoT2023; fix `base.yaml` label columns; first real `repro_baseline` runs	both datasets stream without error
D3	Tune the subsample + confirm clean accuracy on both datasets	**within ~1–2 pts of paper** → S2 passes. Else: pivot to a reproducibility/corrected-evaluation paper (still publishable)
D4	Add end-to-end metric instruments (ASR, benign-drop, detector TPR/FPR) to `src/eval` ; wire an "under perturbation" eval mode	metrics produced on a dry run
D5	Reproduce RADP Layer-1 (GAN + detector) — documented assumptions; GPU session	detector trains; flags a held-out perturbed set
D6	First selector-loop probe on our own model: does concentrating selection on a weak learner measurably change end-to-end robustness?	a measurable effect → S4 is alive
D7	Write up Week-1: reproduction table + corrected-evaluation notes + the S4 plan; freeze a tagged commit	one-page progress report + green CI

End-of-week deliverable: a reproduced, leakage-free MABTSE baseline on both datasets, end-to-end metrics in place, and a first signal on the novel direction — enough to commit to the S4 contribution with confidence.

6. Metrics we instrument from the start

End-to-end **attack-success rate** and **benign-drop rate** (not just post-filter accuracy); detector **TPR/FPR**; **prequential F1/accuracy** over the whole stream; **throughput** (samples/s). These replace the base paper's near-tautological "recovered accuracy".

7. Risks and the enforced rule

Risk	Mitigation
Base paper won't reproduce (underspecified GAN/bandit)	Document every assumption; if it fails, the corrected-evaluation paper is the fallback
Selector effect underwhelms	**Happened (F9).** The label channel became the headline instead; drift-detector manipulation stays a backup
Defence costs too many false alarms	**Mitigated (F14):** IW-strict at ≥ 10% verified; report that 5% is too few for re-weighting
Reviewers ask for an adaptive attacker or a second detector	A-tier only: an attacker that labels benign flows as DDoS (the trusted direction), a second online detector, a third dataset, 5 seeds
Timeline slips	B-tier / workshop (AISec, DLSP) and Q1 journals are the safety net below A-tier

Enforced rule for the whole project: *reproduce before you attack; measure end-to-end, not post-filter; document every assumption; one tagged commit per stage gate.* No stage is "done" until its gate is green.